

Fundamentals of Information Systems Security

Chapter 4 Quiz Answer Key

Instructor: Guuleed Maxamuud Aw Abdi

Section A: Multiple Choice (40 points)

1. **A** — Business Impact Analysis
2. **A** — Recovery Point Objective
3. **A** — Recovery Time Objective
4. **C** — Hot site
5. **B** — HIPAA
6. **B** — GLBA
7. **A** — Bring Your Own Device
8. **C** — PCI DSS
9. **B** — Conducting a BIA
10. **A** — Security gap

Section B: True/False (20 points)

1. **True** — Risk management is essential for longevity
2. **False** — A cold site is the slowest and least expensive
3. **False** — GDPR is an EU regulation
4. **True** — CCPA is California's consumer privacy law
5. **False** — Separation of duties is important for security
6. **True** — Least privilege grants minimum necessary access
7. **False** — SOX applies to public companies
8. **True** — Gap analysis identifies security gaps
9. **True** — FERPA protects student education records
10. **True** — MDM enforces security on mobile devices

Section C: Short Answer (40 points)

1. BIA, BCP, and DRP Relationship (10 points)

- **BIA (Business Impact Analysis):** Identifies critical functions and their recovery requirements
- **BCP (Business Continuity Plan):** Plans for maintaining business operations during disruption
- **DRP (Disaster Recovery Plan):** Focuses on restoring IT infrastructure after disaster
- They work together sequentially: BIA informs BCP and DRP priorities; BCP keeps business running while DRP restores systems

2. Disaster Recovery Site Options (10 points)

- **Hot Site:** Fully operational mirrored facility — Fastest, most expensive
- **Warm Site:** Hardware and utilities but no data — Moderate cost and time
- **Cold Site:** Basic utilities but no equipment — Slowest, least expensive

3. Five Compliance Laws (10 points)

- **HIPAA:** Health data protection
- **GLBA:** Financial institution data protection
- **SOX:** Corporate financial reporting and internal controls
- **GDPR:** EU citizen data protection
- **PCI DSS:** Credit card data protection
- **FERPA:** Student education record protection

4. BYOD Policy Concerns (10 points)

- **Data Ownership:** Employee vs. company data
- **Support Ownership:** Who maintains devices
- **Patch and Antivirus Management:** Device security standards
- **Forensics and Privacy:** Right to investigate during incidents
- **Legal Concerns and AUP:** Policy compliance
- **Onboarding/Offboarding:** Securing data when employees leave